

umm 관리자 운영 가이드 (Admin Guide)

umm 은 사내 폐쇄망 및 오프라인 엔터프라이즈 환경에서 외부 의존성 없이 안정적으로 동작하도록 설계되었습니다.

1. 런타임 환경변수 4종

서비스 기동 시 필요한 환경변수는 정확히 다음 4개뿐이며, 그 외 모든 정책은 관리자 웹 콘솔에서 런타임으로 관리됩니다:

환경변수명	필수 여부	설명	예시
POSTGRES_DSN	필수	PostgreSQL 데이터베이스 연결 문자열	postgres://umm:password@postgres:5432/umm?sslmode=disable
BOOTSTRAP_ADMIN	필수	최초 생성할 시스템 관리자 로그인 아이디	admin
BOOTSTRAP_ADMIN_PASSWORD	필수	부트스트랩 관리자의 초기 비밀번호	ComplexPassword123!
ENCRYPTION_KEY	필수	비밀값 암호화를 위한 32바이트 AES 키	01234567890123456789012345678901

[!NOTE] DB에 이미 bootstrap 관리자가 존재할 경우, 서버를 재시작해도 비밀번호가 임의로 덮어써지지 않습니다.

선택 환경변수 `ENCRYPTION_KEY_PREVIOUS` 는 master-key 회전 기간, `UMM_HTTP_ADDR` 는 listen 주소 변경, 표준 `OTEL_EXPORTER_OTLP_*` 는 trace 전송에만 사용합니다. 필수 입력은 네 개로 유지됩니다.

2. Keycloak OIDC SSO 연동

umm 은 Keycloak OpenID Connect Discovery를 통해 복잡한 설정 없이 엔터프라이즈 SSO를 즉시 연동합니다.

1. Keycloak Client 생성:

- Client type: **OpenID Connect**
- Client authentication: **ON** (Confidential)
- Standard Flow: **ON**
- Valid redirect URIs: **https://<umm-domain>/api/v1/auth/oidc/callback**

2. 관리자 콘솔 설정 (**/admin/oidc**):

- **Keycloak SSO 활성화** 스위치 ON
- **Issuer URL:** **https://keycloak.company.internal/realms/enterprise**
- **Client ID & Client Secret:** Keycloak에서 발급받은 자격증명 입력
- 관리자 그룹/역할: **umm-admins**
- 팀장 그룹/역할: **umm-leads**

3. 연결 시험:

- **연결 시험** 버튼을 클릭하여 OIDC Discovery 및 토큰 엔드포인트 도달 가능 여부를 실시간 검증합니다.

3. Dream Layer & 야간 Scheduler 운영

Dream Layer는 사용자가 밤사이 휴식하는 동안 캔버스에 쌓인 생각들의 의미적 연관성을 분석하고 새로운 아이디어를 제안하는 핵심 백그라운드 엔진입니다.

생성 결과는 v0.6부터 캔버스에 즉시 삽입되지 않고 개인 Dream 검토함에 후보로 저장됩니다. 사용자가 채택할 때만 Dream 메모와 원본 연결선이 함께 생성되며, 기존 버전에서 이미 캔버스에 생성된 Dream은 업그레이드 시 채택 상태로 보존됩니다.

• 스케줄 설정:

- **자동 생성** 스위치 ON
- 생성 시간: 기본 **02:00** (사내 심야 시간대)
- 생성 주기: 매일(Daily), 평일(Weekdays), 주말(Weekends), 특정 요일 선택, N일 간격

• 컨텍스트 & 256K 토큰 한도:

- **최소 메모 개수:** 2개 이상 메모가 있어야 분석 시작
- **분석 범위:** 최근 14일
- **최대 응답 Token:** 4K부터 ****최대 256K (262,144 tokens)****까지 모델 사양에 맞춰 슬라이더로 조절

• 품질 기준선 (Quality Threshold):

- 원본 두 개 이상에 대한 근거성, 적정 새로움, 구체성, 출처 범위를 결합한 내부 최소 점수
- **Quiet Mode:** 가치가 확실하고 영감을 주는 의미 있는 Dream이 없을 경우 불필요한 노이즈 생성을 건너뛰니다.

• 선택 및 개인정보 보호:

- 최근 Dream이 적은 적격 공간을 순환하고, 연결되지 않았으나 의미적으로 이어질 수 있는 메모 조합을 우선합니다.

- 메모 또는 공간에서 AI 제외를 켜면 Scheduler 자격 계산, Dream 생성, AI Assist에서 모두 제외됩니다.

- **운영 지표:**

- 단순 생성 수 외에 검토 완료, 채택률, 편집·연결·확장 기반 유의미 활용률, 채택 Dream당 비용을 함께 확인합니다. 노출 수는 검토함을 불러온 횟수가 아니라 카드가 화면에 50% 이상 실제 표시된 경우만 반영됩니다.

4. 내부 AI Gateway 연동

사내망 내부의 LLM Gateway (vLLM, Ollama, TGI, SGLang 등 OpenAI 호환 서버)를 연결합니다.

- **Base URL:** `http://llm-gateway.internal:8000`, `.../v1`, 전체 `.../chat/completions` 주소를 모두 사용할 수 있습니다.
- **API Key:** 내부 보안 게이트웨이 인증 토큰
- **Timeout:** 긴 추론 모델을 위해 최대 1800초까지 설정 가능
- **vLLM 추론 모델:** 가능하면 서버에 모델별 `--reasoning-parser` 를 설정합니다. 최종 본문 없이 `reasoning` / `reasoning_content` 만 반환하거나 `<think>` 도중 출력 한도에 도달하면, 재시도가 1 이상일 때 umm이 비추론 모드로 다시 요청하고 최종 `content` 만 사용합니다.
- **비용 통계 관리:** 입력/출력 1M 토큰당 비용을 입력하면 관리자 대시보드에서 월간 예상 비용과 사용자당 비용을 실시간으로 추산합니다.

5. RBAC 사용자 관리 및 불변 감사 로그

RBAC 3대 역할 체계

- **admin (관리자):** 모든 공간 조회/수정/삭제, 서비스 설정, 사용자 관리, 감사 로그 열람, Dream 수동 큐 생성
- **team_lead (팀장):** 일반 기능 및 공간 공유 / 외부 내보내기 승인 요청 심사 및 결재 권한
- **user (일반 사용자):** 개인 생각 캔버스 작성, 소유/공유 공간 협업, 개인 키 발급

불변 감사 로그 (Immutable Audit Trail)

- 관리자가 수행한 모든 설정 변경, 사용자 역할 수정, 키 발급, 승인 처리 내역이 `audit_logs` 테이블에 영구 보존됩니다.
- 각 행위의 시각, 행위자, 작업 구분(Action), 대상 리소스(Resource ID)를 투명하게 추적할 수 있습니다.

6. 헬스체크 및 성능 지표 모니터링

경로	메서드	용도	설명
<code>/healthz</code>	GET	Liveness Probe	프로세스 생존 상태 및 버전 반환
<code>/readyz</code>	GET	Readiness Probe	PostgreSQL 연결 및 쿼리 가능 상태 확인
<code>/api/v1/metrics</code>	GET	Prometheus	route별 request count, latency histogram, in-flight, build 정보 (<code>metrics:read</code>)
<code>/mcp</code>	POST	Model Context Protocol	AI 에이전트 도구 연동 엔드포인트

표준 OTLP endpoint 환경변수가 설정된 경우에만 OpenTelemetry HTTP trace exporter가 활성화됩니다. 관리자 운영 현황에는 댓글 수, 온보딩 완료율, 최근 웹훅 실패와 AI 평가 통계도 표시됩니다.

7. Dream AI 평가 회귀

관리자 → AI 평가에서 최소 두 개의 입력 생각, 기대 단어와 금지 단어, Dream 유형을 저장합니다. 실행은 현재 AI Gateway와 prompt version을 그대로 사용하며 grounding, 기대/금지 단어, 구체성, 모델 응답 상태를 0~1 점수와 세부 항목으로 보존합니다. 모델·prompt·Gateway 설정을 바꾸기 전후에 같은 active case를 실행해 회귀를 확인하세요. Gateway 장애도 `error` run으로 남아 평가 이력이 사라지지 않습니다.

8. Master-key 회전

새 키를 `ENCRYPTION_KEY`, 현재 키를 `ENCRYPTION_KEY_PREVIOUS`에 배치한 뒤 재시작합니다. 보안 화면에서 fallback 1개 이상, unreadable 0을 확인하고 **현재 키로 회전**을 실행합니다. 이 작업은 OIDC/AI secret, 웹훅 secret, 암호화 AI prompt를 한 트랜잭션으로 다시 암호화합니다. pending 0을 확인하고 새 백업을 만든 후에만 이전 키 환경 변수를 제거합니다.

9. 서명 웹훅 운영

사용자는 개인 설정에서 허용된 `webhooks:write` scope로 subscription을 관리합니다. 대상은 공개 HTTPS 443만 허용합니다. 도메인 변경과 PostgreSQL delivery outbox는 원자적으로 커밋되고, 재시작 시 대기 또는 lease가 만료된 항목을 이어서 처리합니다. 수신 시스템은 timestamp와 raw body의 HMAC-SHA256, 허용 시간 창을 검증하고 at-least-once 요청의 delivery UUID를 먹등 처리해야 합니다. 일시 실패는 세 번 재시도하고 연속 10회 실패 subscription은 자동 중지됩니다. terminal payload는 즉시 제거되고 metadata도 30일 후 정리되므로 운영 지표와 개인 설정의 마지막 오류를 함께 확인하세요.